Ders 6 Çalışma Özeti

Ders 6 Çalışma Özeti

Genel Konular

- Web güvenlik modeline giriş
  - Web uygulamaları, tarayıcı, sunucu, cookie, JavaScript ve origin kavramları üzerinden erişim kontrolü incelenir.
  - Web modeli işletim sistemi güvenlik modeliyle benzer biçimde subject, object ve operation ilişkileriyle açıklanabilir.
- Cookie ve oturum yönetimi
  - Sunucu, istemciye cookie göndererek oturum durumunu tarayıcıda saklatır.
  - Tarayıcı sonraki isteklerde domain/path gibi kriterlere uyan cookie değerlerini sunucuya geri gönderir.
- Same Origin Policy
  - Bir kaynağın başka bir kaynağın içeriğini okuyup okuyamayacağı origin bilgisine göre sınırlandırılır.
  - Origin; protokol, domain ve port bileşiminden oluşur.
- Cookie erişim kuralları
  - Domain ve path kapsamı cookie'nin hangi isteklerde gönderileceğini belirler.
  - Yanlış kapsamlandırılan cookie daha geniş alanda kullanılabilir ve saldırı yüzeyini büyütür.
- Web üzerinden saldırı yüzeyi
  - Kötü niyetli site yönlendirmeleri, router ele geçirilmesi, zararlı içerik ve cookie ele geçirme riskleri değerlendirilir.

Hocanın Özellikle Vurguladığı Kısımlar

- Cookie kimlik doğrulamanın kritik parçasıdır
  - Cookie ele geçirilirse oturumun ele geçirilmesi mümkündür.
- Same Origin Policy içerik okuma sınırıdır
  - Kaynağa istek atabilmek ile cevabın içeriğini okuyabilmek aynı şey değildir.
- Cookie kapsamı dikkatli belirlenmelidir
  - Domain ve path değeri gereğinden geniş seçilirse least privilege ihlal edilir.

Kısa Tekrar Notları

- Cookie sunucunun tarayıcıda saklattığı durum bilgisidir.
- Session management çoğu web uygulamasında cookie ile yapılır.
- Same Origin Policy: protokol + domain + port eşleşmesi.
- Cookie theft oturum ele geçirmeye yol açabilir.
- Domain/path cookie gönderim kapsamını belirler.

Detaylı Açıklamalar

- Web uygulamalarında HTTP stateless olduğu için sunucu, kullanıcıyı sonraki isteklerde tanımak amacıyla cookie kullanır. Kullanıcı adı ve parola ile başarılı girişten sonra sunucu session değeri içeren bir cookie döndürebilir. Tarayıcı bu cookie'yi saklar ve uygun isteklerde tekrar gönderir.

- Same Origin Policy, web güvenliğinin temel erişim kontrol mekanizmasıdır. Bir sayfa başka kaynağa istek gönderebilir; ancak cevabın okunması origin politikasına bağlıdır. Bu ayrım CSRF, XSS ve cookie theft gibi saldırıları anlamak için önemlidir.
- Cookie'lerin domain ve path kapsamı doğru belirlenmezse bir alt alan adı veya farklı yol beklenmeyen cookie değerlerine erişebilir ya da onları gönderebilir. Bu nedenle cookie kapsamı en az yetki ilkesiyle uyumlu ayarlanmalıdır.
- **Not:** İsterseniz bu dersin altyazı (.srt) dosyasını Gemini Notebook gibi bir yapay zeka aracına yükleyerek ders hakkında daha detaylı soru-cevaplar yapabilir ve dersi verimli çalışabilirsiniz.